

Sprint 4 – Group Meeting Notes

Meeting Schedule with mentor (Steve)

- Sprint-3_Meeting-Notes: February 17 – March 3, 2026
- **Meeting Type:** Group meetings with mentor
- **Project:** Open Energy Dashboard (OED)

Role Assignment

- Oyekunle Alabi

General Summary

During Sprint 4, the team met with the mentor to discuss ongoing progress on security-related tasks within the Open Energy Dashboard (OED) project. The meeting focused on updates regarding log injection fixes, rate limiting tests, pull request reviews, database upgrades, and additional security research tasks.

Overall, the team continues to make steady progress. Some issues are close to completion, while others require additional testing, research, or adjustments before they can be finalized.

Issue 16 – Log Injection and Input Sanitization

The team reported significant progress on Issue 16, which focuses on resolving log injection vulnerabilities.

Work completed includes:

- Identifying routes affected by the vulnerability
- Reproducing the issue using curl commands similar to those used in the penetration testing report
- Implementing input sanitization through a helper file
- Verifying that malicious input no longer affects logs

Additional routes that followed the same code pattern were also reviewed to ensure they did not contain the same vulnerability.

Next Step:

Submit the completed fix as a pull request and verify that all potentially affected routes are covered.

Issue 12 – Rate Limiting Testing

Work on Issue 12 continues, particularly regarding testing the login rate limiting feature.

The main challenge comes from the current testing configuration. Automated tests run in a special environment where rate limits are multiplied by a large factor. This prevents tests from triggering the rate limit, making it difficult to verify that the protection works properly.

The mentor explained that this behavior is controlled by an environment variable used during automated testing.

Suggested approach:

- Create a separate testing setup that does not apply the testing environment variable
- Allow the system to behave as it would in production so the rate limit can be triggered during tests

Next Step:

Implement a new testing configuration that allows rate-limiting behavior to be tested correctly.

Pull Request Updates

The team discussed several pull requests currently in progress.

One pull request related to Issue 2 has been updated and is ready for another review. Additional work was pushed recently and is awaiting feedback.

Another pull request related to Issue 14 has been submitted as a draft. The changes modify how error responses are returned, which currently causes some automated tests to fail. Further adjustments to the tests will be required before the pull request can be finalized.

HTTP Request and Status Code Corrections

Work has begun on correcting incorrect HTTP request methods and status codes across several routes.

Some routes currently use incorrect HTTP methods (for example, POST instead of GET), and some responses return incorrect status codes.

The task involves:

- Reviewing route definitions
- Verifying the correct HTTP request methods
- Adjusting incorrect status codes

These corrections may require updating some existing tests if expected results change.

Database Version Upgrade (Postgres and Node)

The team also discussed upgrading the Postgres and Node versions to address known CVE vulnerabilities.

Initial attempts to upgrade directly caused conflicts with the existing database. The mentor explained that upgrading a database on an existing installation can lead to compatibility issues.

The recommended approach is to:

1. Clone a fresh copy of the OED repository
2. Update the Postgres and Node versions
3. Start the application and recreate the database
4. Insert the test data and verify that the system runs correctly

If the fresh installation works, the next step will be reviewing the Postgres documentation to determine the correct migration process between versions.

Issue 5 – Vault and Database Credentials Research

Research related to secure management of database credentials using a vault-style solution has been completed and uploaded to the team repository.

The mentor will review the research and the recommendations included. The research explores ways to securely store credentials instead of relying on environment variables.

Issue 4 – Insecure Docker Configuration

The team also discussed Issue 4, which focuses on improving Docker security configuration.

Areas identified for investigation include:

- Docker resource limits
- Writable files and directories
- Running containers as the root user

Some concerns related to environment variables may be addressed later once a vault-based solution is implemented.

Testing Issue – User Account Creation

While testing one of the issues, a problem occurred when attempting to create a CSV user account.

The mentor clarified that developers should first log in using the default test administrator account provided in the development environment. After logging in as the admin user, additional users can be created through the system's admin interface.

This clarification should allow testing to continue normally.

Sprint Reflection

Sprint 4 progress remains steady. Several issues are close to completion, while others require additional testing or documentation.

The team gained clearer direction on how to properly test rate-limiting behavior, handle database upgrades safely, and review pull requests more effectively.

Although some technical challenges remain, the team now has a clearer plan for completing the remaining security improvements.

Next Steps

- Submit and review the pull request for Issue 16
- Complete the new testing setup for Issue 12
- Finalize pull request updates for Issues 2 and 14
- Continue correcting HTTP request methods and status codes
- Test compatible versions of Postgres and Node
- Review research on vault-based credential management
- Investigate improvements for Docker security configuration